

Dan Boneh 《Cryptography I》第三课：分组密码

依据课程原版讲义 [03-block-v2-annotated.pdf](#) (65 页) 整理。

本课主线：分组密码 → PRF/PRP → DES 与 Feistel → 穷举与中间相遇攻击 → 线性、侧信道和量子攻击 → AES → 从 PRG 构造 PRF/PRP。

0. 本课要解决的问题

上一课使用伪随机生成器构造流密码：

$$c = m \oplus G(k)$$

这一课研究另一类核心密码学原语：**分组密码 (block cipher)**。

分组密码接收一个固定长度的明文分组，在密钥控制下，把它变换为相同长度的密文分组：

$$E : \mathcal{K} \times \{0, 1\}^n \rightarrow \{0, 1\}^n$$

对每个固定密钥 k ， $E(k, \cdot)$ 都是一个可逆置换。

本课需要回答：

1. 分组密码为什么应被看作伪随机置换？
2. PRF、PRP 和真正随机函数、随机置换有什么区别？
3. Feistel 网络为什么能把任意轮函数变成可逆函数？
4. DES 为什么被淘汰？3DES、DESX 如何延长其寿命？
5. 为什么双重 DES 没有提供预期的 112 位安全性？
6. 线性密码分析、侧信道和量子搜索分别攻击什么？
7. AES 的一轮包含哪些步骤，为什么最后一轮不同？
8. 如何从 PRG 理论上构造 PRF，再构造 PRP？

1. 什么是分组密码

1.1 基本接口

设：

- 密钥长度为 k 位；
- 分组长度为 n 位；
- 明文分组和密文分组都属于 $\{0, 1\}^n$ 。

加密算法：

$$E : \{0, 1\}^k \times \{0, 1\}^n \rightarrow \{0, 1\}^n$$

解密算法：

$$D : \{0, 1\}^k \times \{0, 1\}^n \rightarrow \{0, 1\}^n$$

正确性要求：

$$\forall k, m, \quad D(k, E(k, m)) = m$$

因此，对固定密钥 k ，映射

$$E_k(\cdot) = E(k, \cdot)$$

必须是一一映射。在有限且定义域、值域相同的集合上，一一映射也就是置换。

1.2 典型参数

算法	分组长度	密钥长度	现状
DES	64 位	56 位有效密钥	已淘汰
3DES	64 位	名义上 168 位	已逐步淘汰
AES-128	128 位	128 位	广泛使用
AES-192	128 位	192 位	可用
AES-256	128 位	256 位	广泛使用

注意：**分组长度和密钥长度是两个不同参数。**

- 分组长度决定一次变换的数据大小和某些碰撞边界。
- 密钥长度主要决定通用穷举攻击的成本。

1.3 分组密码不能直接加密任意长消息

分组密码只定义了单个固定长度分组上的置换。要安全加密长消息，还需要工作模式或认证加密方案。

例如 AES 本身只是 128 位分组上的置换；AES-GCM、AES-CTR 等才是处理长消息的方案。本讲 PPT 重点是分组密码原语本身，工作模式属于后续内容。

1.4 迭代结构

实际分组密码通常由多轮变换组成：

```

主密钥 k
  |
密钥扩展
  |
轮密钥 k1, k2, ..., kr

明文 -> R(k1, .) -> R(k2, .) -> ... -> R(kr, .) -> 密文
  
```

R 称为轮函数。多轮设计的目标是让简单的局部变换逐渐产生复杂的全局行为。

AES-128 使用 10 轮；DES 使用 16 轮 Feistel 网络。PPT 中“3DES 为 48 轮”指三次执行 16 轮 DES 的总轮数。

2. PRF 与 PRP

分组密码的安全性不能只说“看起来很乱”。课程通过 PRF 和 PRP 给出严格抽象。

2.1 伪随机函数 PRF

定义在 $(\mathcal{K}, \mathcal{X}, \mathcal{Y})$ 上的伪随机函数族为：

$$F : \mathcal{K} \times \mathcal{X} \rightarrow \mathcal{Y}$$

要求存在高效算法计算 $F(k, x)$ 。

固定密钥 k 后，可以得到一个普通函数：

$$F_k : \mathcal{X} \rightarrow \mathcal{Y}, \quad F_k(x) = F(k, x)$$

所有密钥对应的函数组成：

$$S_F = \{F(k, \cdot) : k \in \mathcal{K}\}$$

2.2 真正随机函数

从 $\mathcal{X}$ 到 $\mathcal{Y}$ 的所有函数构成：

$$\text{Funs}[\mathcal{X}, \mathcal{Y}]$$

其大小为：

$$|\text{Funs}[\mathcal{X}, \mathcal{Y}]| = |\mathcal{Y}|^{|\mathcal{X}|}$$

真正随机函数 f 是从这个巨大集合中均匀选取的函数。

它具有两个重要特征：

- 同一输入重复查询时，答案始终相同；
- 对从未查询过的新输入，输出独立且均匀随机。

2.3 安全 PRF 的直觉

攻击者可以自适应选择输入 $x_1, x_2, \dots$ ，并观察返回值。它面对的 oracle 是以下二者之一：

$$F(k, \cdot), \quad k \leftarrow \mathcal{K}$$

或

$$f \leftarrow \text{Funs}[\mathcal{X}, \mathcal{Y}]$$

若任意高效攻击者都无法以不可忽略优势判断自己面对哪一种，则 F 是安全 PRF。

可将优势写为：

$$\text{Adv}_{\text{PRF}}[A, F] = \left| \Pr[A^{F(k, \cdot)} = 1] - \Pr[A^f = 1] \right|$$

上标表示攻击者可以查询这个函数 oracle，而不是只得到单个样本。

2.4 伪随机置换 PRP

伪随机置换定义为：

$$E : \mathcal{K} \times \mathcal{X} \rightarrow \mathcal{X}$$

并满足：

1. $E(k, x)$ 可高效计算；
2. 对每个 k , $E(k, \cdot)$ 是一一映射；
3. 存在高效逆算法 $D(k, y)$ 。

所有 $\mathcal{X}$ 上的置换构成：

$$\text{Perms}[\mathcal{X}]$$

若随机密钥选出的 $E(k, \cdot)$ 与均匀随机置换

$$\pi \leftarrow \text{Perms}[\mathcal{X}]$$

对高效攻击者不可区分，则 E 是安全 PRP。

2.5 PRF 与 PRP 的关系

性质	PRF	PRP
输入空间	$\mathcal{X}$	$\mathcal{X}$
输出空间	$\mathcal{Y}$	必须也是 $\mathcal{X}$
是否一一映射	不要求	要求
是否可逆	不要求	要求高效可逆
理想对象	随机函数	随机置换

从功能上看，PRP 是一种特殊 PRF：它的输入输出空间相同，并且可逆。

AES 和 3DES 都是 PRP 候选，也就是实际分组密码。

2.6 一个不安全 PRF 的例子

设 F 是安全 PRF，定义：

$$G(k, x) = \begin{cases} 0^{128}, & x = 0 \\ F(k, x), & x \neq 0 \end{cases}$$

攻击者查询 $x = 0$ ：

- 若返回 0^{128} ，猜测 oracle 是 G ；
- 否则猜测是真随机函数。

对 G ，返回 0^{128} 的概率为 1；对随机函数，该概率只有 2^{-128} 。区分优势接近 1，因此 G 完全不安全。

结论：即使只在一个特殊输入上表现异常，也足以破坏 PRF 安全性。

3. PRF 可以构造 PRG

设：

$$F : \mathcal{K} \times \{0, 1\}^n \rightarrow \{0, 1\}^n$$

是安全 PRF。定义：

$$G(k) = F(k, 0) \parallel F(k, 1) \parallel \cdots \parallel F(k, t-1)$$

则：

$$G : \mathcal{K} \rightarrow \{0, 1\}^{nt}$$

是安全 PRG。

3.1 为什么安全

若 $F(k, \cdot)$ 与随机函数 $f(\cdot)$ 不可区分，则：

$$F(k, 0), F(k, 1), \dots, F(k, t-1)$$

与随机函数在不同输入上的输出不可区分。随机函数对不同新输入返回独立均匀的 n 位串，所以拼接结果与均匀随机的 nt 位串不可区分。

3.2 工程性质

所有块

$$F(k, 0), F(k, 1), \dots, F(k, t-1)$$

可以并行计算。这正是使用分组密码实现计数器式密钥流的理论基础之一。

4. DES 的历史与参数

4.1 简史

- 20 世纪 70 年代初：IBM 的 Horst Feistel 设计 Lucifer，密钥和分组均为 128 位。
- 1973 年：NBS 征集分组密码方案。
- 1976 年：DES 成为美国联邦标准。
- DES 参数：64 位分组、56 位有效密钥。
- 1997 年：DES 已能被穷举攻破。
- 2000 年：NIST 选择 Rijndael 作为 AES，替代 DES。

4.2 DES 为什么失败

DES 的主要现实问题是 **56 位密钥过短**，而不是已发现一个能瞬间破解完整 DES 数学结构的攻击。

穷举密钥空间只需测试：

$$2^{56}$$

个候选密钥。随着硬件发展，这个规模已不再安全。

此外，64 位分组也过小，不适合今天的大数据量加密场景。

5. Feistel 网络

Feistel 网络是 DES 的核心结构。它解决了一个重要问题：

如何用不一定可逆的轮函数，构造一个整体可逆的分组密码？

5.1 单轮公式

把 $2n$ 位输入分成左右两半：

$$(R_{i-1}, L_{i-1})$$

按 PPT 的标记，一轮计算：

$$L_i = R_{i-1}$$

$$R_i = f_i(R_{i-1}) \oplus L_{i-1}$$

注意：有些教材把左右命名写成相反顺序，但结构完全等价。

5.2 为什么可逆

已知输出 (R_i, L_i) ：

$$R_{i-1} = L_i$$

再由

$$R_i = f_i(R_{i-1}) \oplus L_{i-1}$$

得到：

$$L_{i-1} = f_i(L_i) \oplus R_i$$

因此，无论 f_i 是否可逆，整个 Feistel 轮都可逆。

这是因为解密只需重新计算 $f_i(L_i)$ ，而不需要求 f_i^{-1} 。

5.3 解密电路

Feistel 解密与加密使用基本相同的结构，只需将轮函数或轮密钥按相反顺序使用：

加密： $k_1, k_2, \dots, k_r$
解密： $k_r, \dots, k_2, k_1$

这使 Feistel 结构尤其适合硬件实现。

5.4 Luby-Rackoff 定理

设

$$f : \mathcal{K} \times \{0, 1\}^n \rightarrow \{0, 1\}^n$$

是安全 PRF。Luby-Rackoff 定理表明：使用独立密钥的三轮 Feistel 网络可以构造一个安全 PRP：

$$F : \mathcal{K}^3 \times \{0, 1\}^{2n} \rightarrow \{0, 1\}^{2n}$$

这条定理建立了重要桥梁：

安全 PRF
↓ 三轮 Feistel
安全 PRP (分组密码)

这里讨论的是课程中的基本 PRP 安全模型。更强的攻击模型可能需要更多轮。

6. DES 的内部结构

6.1 总体结构

DES 是 16 轮 Feistel 网络：

$$f_i(x) = F(k_i, x)$$

其中：

- 输入分组：64 位；
- 左右各 32 位；
- 主密钥产生 16 个轮密钥；
- 加密前后还有初始置换 IP 和逆置换 IP^{-1} ；
- 解密时反向使用轮密钥。

初始置换主要是历史硬件布线因素，并不是 DES 安全性的核心来源。

6.2 DES 轮函数

对 32 位右半部分，一轮大致执行：

1. 扩展置换：32 位扩展为 48 位；
2. 与 48 位轮密钥异或；
3. 送入 8 个 S-box；
4. 每个 S-box 将 6 位映射为 4 位；
5. 合计恢复为 32 位；
6. 再经过 P-box 置换。

S-box：

$$S_i : \{0, 1\}^6 \rightarrow \{0, 1\}^4$$

是查找表，也是 DES 非线性的主要来源。

6.3 为什么 S-box 不能是线性的

如果 S-box 可以写成二进制矩阵变换：

$$S_i(x) = A_i x \pmod{2}$$

那么异或、置换和线性 S-box 的组合仍然是线性的，整个 DES 最终可写成：

$$c = B \begin{bmatrix} m \\ k_1 \\ \vdots \\ k_{16} \end{bmatrix} \pmod{2}$$

于是会出现可利用关系，例如：

$$E(k, m_1) \oplus E(k, m_2) \oplus E(k, m_3) = E(k, m_1 \oplus m_2 \oplus m_3)$$

攻击者可以用少量明密文建立线性方程并恢复信息。

6.4 混淆与扩散

从 DES 和 AES 的设计都能看到两类目标：

- **混淆 (confusion)**：让密钥、明文与密文之间的关系高度非线性，主要依赖 S-box。
- **扩散 (diffusion)**：让一个输入位的影响传播到许多输出位，依赖置换、行移位、列混合和多轮迭代。

优秀 S-box 不能只是“随机挑一个表”。PPT 强调，随机选择 S-box 和 P-box 也可能得到不安全设计。设计者必须控制线性偏差、差分特征等密码分析指标。

7. 穷举密钥攻击

7.1 攻击模型

攻击者知道若干明密文对：

$$(m_i, c_i), \quad c_i = E(k, m_i)$$

它枚举每个候选密钥 k' ，检查：

$$E(k', m_i) \stackrel{?}{=} c_i$$

若密钥长度是 s 位，通用穷举攻击时间约为：

$$O(2^s)$$

平均情况下约测试一半密钥，即 2^{s-1} 次。

7.2 为什么需要多组明密文

对理想 DES，密钥空间大小为 2^{56} ，密文分组空间大小为 2^{64} 。

固定一组 (m, c) ，错误密钥碰巧满足 $E(k', m) = c$ 的期望数量约为：

$$\frac{2^{56} - 1}{2^{64}} \approx 2^{-8}$$

所以一组明密文通常已经能唯一确定密钥，概率约为：

$$1 - 2^{-8} = 1 - \frac{1}{256}$$

使用两组明密文后，错误密钥同时通过的概率更低。PPT 给出：

- 两组 DES 明密文的唯一性概率约为 $1 - 2^{-71}$ ；
- 对 AES-128，两组明密文的唯一性概率约为 $1 - 2^{-128}$ 。

因此穷举时通常只需少量明密文对就能验证正确密钥。

7.3 DES 穷举历史

PPT 列出：

- 1997：互联网协作搜索，约 3 个月；
- 1998：EFF Deep Crack，约 3 天；
- 1999：组合搜索，约 22 小时；
- 2006：COPACOBANA，约 7 天，成本约 1 万美元。

结论：56 位密钥的密码不应再使用。

8. 为什么双重 DES 不够安全

8.1 朴素期望

双重加密定义为：

$$2E((k_1, k_2), m) = E(k_1, E(k_2, m))$$

两个 56 位密钥看起来构成 112 位密钥，因此似乎需要 2^{112} 次穷举。

但中间状态提供了更好的攻击方法。

8.2 中间相遇攻击

对已知明密文 (m, c) ，正确密钥满足：

$$E(k_2, m) = D(k_1, c)$$

攻击步骤：

1. 枚举全部 2^{56} 个 k_2 ，计算 $E(k_2, m)$ ，存入表中。
2. 按中间值排序或使用哈希表。
3. 枚举全部 2^{56} 个 k_1 ，计算 $D(k_1, c)$ 。
4. 在表中查找相同中间值。
5. 使用更多明密文对排除碰撞产生的假候选。

8.3 复杂度

时间约为：

$$2^{56} + 2^{56}$$

加上排序成本，PPT 将其上界写为小于 2^{63} ；空间约为：

$$2^{56}$$

这远小于 2^{112} 。因此双重 DES 并没有提供真正的 112 位安全性。

8.4 核心经验

把两个密码简单串联，不代表安全位数直接相加。

分析多重加密时，必须检查攻击者能否从明文端和密文端分别计算，并在中间状态相遇。

9. Triple DES 与 DESX

9.1 三重加密

课程先分析一般的三重级联：

$$3E((k_1, k_2, k_3), m) = E(k_1, E(k_2, E(k_3, m)))$$

三个 DES 密钥名义上共有：

$$3 \times 56 = 168$$

位，性能约为 DES 的三分之一。

中间相遇思想仍能攻击三重级联，PPT 给出的简单攻击时间约为：

$$2^{118}$$

空间约为 2^{56} ，所以有效安全性明显低于名义上的 168 位。

实际标准中的 3DES 常使用 EDE 结构，即加密-解密-加密，以便兼容旧 DES；这里不影响课程关于多重加密与中间相遇攻击的核心结论。

9.2 DESX：密钥白化

DESX 在 DES 前后加入异或白化：

$$E_X((k_1, k_2, k_3), m) = k_1 \oplus E(k_2, m \oplus k_3)$$

其中：

- k_3 ：输入白化密钥，64 位；
- k_2 ：DES 密钥，56 位；
- k_1 ：输出白化密钥，64 位。

名义密钥总长度：

$$64 + 56 + 64 = 184 \text{ 位}$$

但 PPT 给出的简单攻击时间约为：

$$2^{64+56} = 2^{120}$$

所以名义密钥长度仍不等于有效安全强度。

9.3 为什么需要前后都白化

若只进行输出白化：

$$k_1 \oplus E(k_2, m)$$

则对每个候选 k_2 ，可由一组明密文直接确定 k_1 ，再用其他样本验证；并未得到简单相加的安全性。

只做输入白化也有类似问题。前后白化共同使用才能获得 DESX 设计想要的强化效果。

10. 实现攻击

即使算法在数学模型中安全，实现仍可能泄露密钥。

10.1 侧信道攻击

攻击者不直接破解数学关系，而是测量实现的物理信息：

- 运行时间；
- 功耗；
- 电磁辐射；
- 缓存访问；
- 声音或其他硬件行为。

若某个中间步骤是否执行、访问哪个表项取决于密钥，观测值就可能与密钥位相关。

10.2 故障攻击

攻击者主动让设备产生计算错误，例如：

- 改变电压或时钟；
- 使用激光或电磁干扰；
- 使最后一轮出现局部错误。

比较正确输出和故障输出，有时能推断最后一轮密钥，再逆推出主密钥。

10.3 课程结论

不要自己实现密码学原语。

更完整的工程原则是：使用经过广泛审计、提供常数时间或硬件加速实现的成熟密码库，并使用高层认证加密接口。

11. 线性密码分析

11.1 基本思想

线性密码分析寻找一个略有偏差的线性关系。设：

$$c = \text{DES}(k, m)$$

如果对随机 m, k ，存在若干明文位、密文位和密钥位，使：

$$\Pr[m[i_1] \oplus \cdots \oplus m[i_r] \oplus c[j_1] \oplus \cdots \oplus c[j_v] = k[l_1] \oplus \cdots \oplus k[l_u]] = \frac{1}{2} + \varepsilon$$

其中 $\varepsilon \neq 0$ ，就说明这个关系比随机猜测稍微可靠。

11.2 微小偏差如何变成攻击

单个样本上， ε 可能极小。但收集约

$$\frac{1}{\varepsilon^2}$$

组随机明密文后，可以通过多数表决识别偏差。

PPT 给出：若样本数约为 $1/\varepsilon^2$ ，多数表决正确恢复相应密钥位组合的概率可达到约 97.7%。

11.3 DES 的参数

对 DES，可找到偏差约为：

$$\varepsilon = 2^{-21}$$

因此需要约：

$$\frac{1}{\varepsilon^2} = 2^{42}$$

组明密文。

课程给出的粗略攻击：

1. 用 2^{42} 组样本恢复约 14 位密钥信息；
2. 穷举剩余 $56 - 14 = 42$ 位；
3. 总时间约为 2^{43} ，低于 2^{56} 。

11.4 关键教训

S-box 中极小的线性偏差，经过大量样本和多轮传播后，也可能变成实质攻击。

因此：

- 非线性组件的选择必须经过严格分析；
- 不要自行设计密码算法；
- “没有明显规律”并不是安全证据。

11.5 差分密码分析

PPT 同时提到差分密码分析。其核心不是寻找单个输入输出的线性关系，而是研究输入差分如何影响输出差分：

$$\Delta x = x \oplus x'$$

$$\Delta y = E_k(x) \oplus E_k(x')$$

若某些差分传播路径出现概率显著高于随机水平，攻击者可用大量选择明文对推断轮密钥。

12. 量子穷举攻击

12.1 Grover 搜索

设：

$$f : \mathcal{X} \rightarrow \{0, 1\}$$

目标是找到满足 $f(x) = 1$ 的 x 。

- 经典通用搜索： $O(|\mathcal{X}|)$ ；
- Grover 量子搜索： $O(\sqrt{|\mathcal{X}|})$ 。

12.2 用于密钥搜索

已知 $m, c = E(k, m)$ ，定义：

$$f(k') = \begin{cases} 1, & E(k', m) = c \\ 0, & \text{其他} \end{cases}$$

若密钥空间大小为 2^s ，Grover 算法将理想查询复杂度从 2^s 降为：

$$2^{s/2}$$

因此：

- DES：约 2^{28} ；
- AES-128：约 2^{64} ；
- AES-256：约 2^{128} 。

12.3 正确理解

Grover 提供平方级加速，而不是把所有对称密码瞬间破解。为抵抗通用量子穷举，通常可以加倍密钥长度。

实际运行 Grover 还需要巨大的容错量子计算资源，门数、深度、纠错成本都不可忽略。因此 $2^{s/2}$ 是理解安全级别的理想化指标，不等于现实攻击时间。

13. AES

13.1 AES 竞赛

- 1997：NIST 发布征集。

- 1998：收到 15 个候选方案。
- 1999：选出 5 个决赛方案。
- 2000：选择比利时密码学家设计的 Rijndael 作为 AES。

AES 固定使用 128 位分组，支持：

128, 192, 256 位密钥

对应轮数分别是：

版本	密钥长度	轮数
AES-128	128 位	10
AES-192	192 位	12
AES-256	256 位	14

13.2 AES 不是 Feistel 网络

AES 使用代换-置换网络（Substitution-Permutation Network, SPN）。

Feistel 只让一半状态经过轮函数，再与另一半异或；AES 每轮直接对整个 128 位状态进行一系列可逆变换。

因此 AES 的每个主要步骤本身都需要可逆，解密时依次使用逆变换。

13.3 状态矩阵

AES 把 128 位分组视为 16 个字节，并排列成 4×4 状态矩阵：

$$S = \begin{bmatrix} s_{0,0} & s_{0,1} & s_{0,2} & s_{0,3} \\ s_{1,0} & s_{1,1} & s_{1,2} & s_{1,3} \\ s_{2,0} & s_{2,1} & s_{2,2} & s_{2,3} \\ s_{3,0} & s_{3,1} & s_{3,2} & s_{3,3} \end{bmatrix}$$

AES 规范按列填充输入字节。理解这一点对手算测试向量和阅读实现很重要。

13.4 AES-128 整体流程

初始步骤：

$\text{AddRoundKey}(S, k_0)$

前 9 轮依次执行：

1. SubBytes
2. ShiftRows
3. MixColumns
4. AddRoundKey

第 10 轮执行：

1. SubBytes
2. ShiftRows

3. AddRoundKey

最后一轮没有 MixColumns。

课程 PPT 使用 ByteSub、ShiftRow、MixColumn 的名称，分别对应规范中常见的 SubBytes、ShiftRows、MixColumns。

14. AES 一轮的四个步骤

14.1 SubBytes

对状态中的每个字节独立应用同一个 8 位 S-box：

$$S : \{0, 1\}^8 \rightarrow \{0, 1\}^8$$

它是 256 项的可逆查找表，为 AES 提供非线性。

AES S-box 并非任意随机表，而是基于 $GF(2^8)$ 中的乘法逆元，再加仿射变换构造。

14.2 ShiftRows

状态矩阵各行循环左移不同字节数：

第 0 行：移动 0 字节
第 1 行：移动 1 字节
第 2 行：移动 2 字节
第 3 行：移动 3 字节

它让原本位于同一列的字节分散到不同列，为跨列扩散做准备。

14.3 MixColumns

把每一列看作 $GF(2^8)$ 上的四维向量，与固定可逆矩阵相乘：

$$\begin{bmatrix} 02 & 03 & 01 & 01 \\ 01 & 02 & 03 & 01 \\ 01 & 01 & 02 & 03 \\ 03 & 01 & 01 & 02 \end{bmatrix} \begin{bmatrix} s_{0,c} \\ s_{1,c} \\ s_{2,c} \\ s_{3,c} \end{bmatrix}$$

它把一列中每个输入字节的影响扩散到该列的四个输出字节。

14.4 AddRoundKey

状态与轮密钥逐位异或：

$$S \leftarrow S \oplus k_i$$

这是轮中直接引入密钥的步骤。异或的逆就是自身，因此解密也使用异或。

14.5 多轮如何产生雪崩效应

单个输入字节经过：

SubBytes：非线性替换

ShiftRows：移动到另一列

MixColumns：影响整列

下一轮 ShiftRows/MixColumns：传播到更多位置

经过多轮，一个输入位或密钥位的改变会影响大量输出位，这就是雪崩效应。

15. AES 密钥扩展

AES-128 的 16 字节主密钥扩展为 11 个 16 字节轮密钥：

$$k_0, k_1, \dots, k_{10}$$

总计：

$$11 \times 16 = 176 \text{ 字节}$$

密钥扩展使用字循环、S-box 替换、轮常量和异或递推。

它本身是确定性的；轮密钥不是彼此独立随机的。密码分析必须同时考虑主轮函数和密钥扩展结构。

16. AES 的实现与性能

16.1 表驱动实现

课程给出代码体积与速度的取舍：

策略	代码/表大小	性能
预计算完整轮函数表	最大	最快，主要做查表和异或
只预计算 S-box	较小	较慢
不预计算	最小	最慢

传统软件实现可以把 SubBytes、ShiftRows 和 MixColumns 合并进 T-table。

但查表索引若依赖秘密状态，缓存访问模式可能泄露密钥。因此现代安全实现不能只追求速度，还必须考虑侧信道。

16.2 AES 硬件指令

Intel AES-NI 等指令直接在 CPU 中完成 AES 轮操作：

- aesenc：执行普通加密轮；
- aesenclast：执行最后一轮；
- aeskeygenassist：辅助密钥扩展。

硬件指令通常同时带来：

- 更高速度；
- 更小代码；
- 避免传统查表缓存侧信道。

16.3 课程中的 AES 攻击结论

PPT 给出的结论是：对完整 AES 的最佳公开密钥恢复攻击只比穷举快一个很小常数因子，并不构成现实破解。

PPT 还提到 AES-256 的相关密钥攻击：攻击者需要来自多个具有特定关系的密钥的大量明密文。这不等同于在标准随机独立密钥模型下攻破 AES-256。

17. 从 PRG 构造 PRF：GGM

这一段回答一个理论问题：

如果只假设安全 PRG 存在，能否构造安全 PRF，进而构造安全分组密码？

答案是可以。

17.1 一位输入的 PRF

设安全 PRG：

$$G : \mathcal{K} \rightarrow \mathcal{K}^2$$

把输出分成左右两半：

$$G(k) = G(k)[0] \parallel G(k)[1]$$

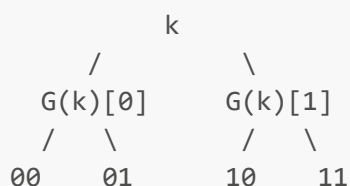
定义：

$$F(k, x) = G(k)[x], \quad x \in \{0, 1\}$$

输入 0 返回左半，输入 1 返回右半。若 G 安全，这两个输出与两个独立随机的 $\mathcal{K}$ 元素不可区分，因此得到一位输入的安全 PRF。

17.2 两位输入

继续把左右子种子分别送入 G ，形成深度为 2 的二叉树：



输入 $x = x_0x_1$ 决定从根开始走左分支还是右分支，最后输出对应叶子。

17.3 一般 GGM 构造

对于：

$$x = x_0x_1 \cdots x_{n-1} \in \{0, 1\}^n$$

令：

$$k_0 = k$$

逐层计算：

$$k_{i+1} = G(k_i)[x_i]$$

最终定义：

$$F(k, x) = k_n$$

也就是说，输入的每一位决定在 PRG 二叉树中向左还是向右。

17.4 为什么安全

证明使用混合实验：逐个把树中的 PRG 输出替换为独立随机值。

如果攻击者能区分最终 GGM 函数与真正随机函数，那么在某一次替换前后，它必然具有不可忽略区分优势。利用这个攻击者即可区分 $G(k)$ 和随机的两个 $\mathcal{K}$ 元素，从而违背 PRG 安全性。

因此：

$$G \text{ 是安全 PRG} \implies F_{\text{GGM}} \text{ 是安全 PRF}$$

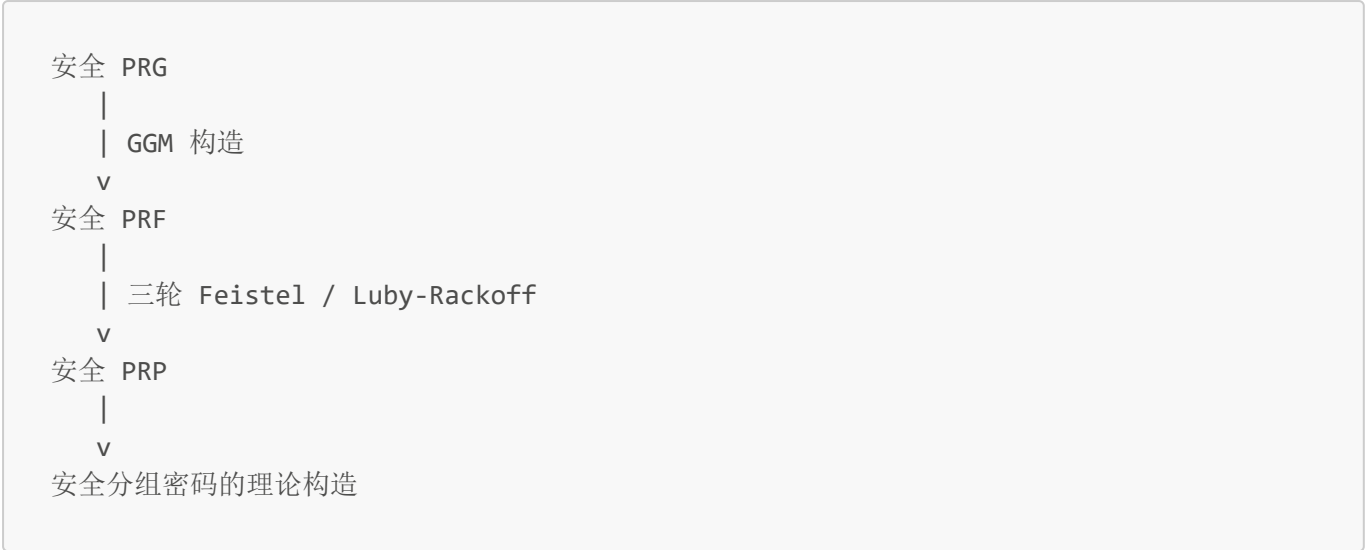
17.5 为什么不直接用于实践

对一个 n 位输入，GGM 需要顺序调用 PRG n 次。路径上的每一步依赖前一步输出，难以并行，因此性能较慢。

GGM 的主要价值是理论上的存在性证明，而不是作为 AES 的实际实现方案。

18. 从 PRG 到分组密码的完整理论链

本课最后把多个结论串起来：



即：

安全 PRG 存在 $\implies$ 安全 PRF 存在 $\implies$ 安全 PRP 存在

这说明，构造流密码所需的基本计算假设，也足以在理论上构造分组密码。

实际 AES 并不是用 GGM 再套 Feistel 构造出来的；它采用更高效的专门 SPN 设计。理论构造回答“能否存在”，实际密码回答“怎样高效实现”。

19. 核心概念对照

概念	固定密钥后是什么	理想对象	是否可逆
PRG	从短种子产生长输出	均匀随机串	不要求
PRF	函数 $F_k : \mathcal{X} \rightarrow \mathcal{Y}$	随机函数	不要求
PRP	置换 $E_k : \mathcal{X} \rightarrow \mathcal{X}$	随机置换	要求
分组密码	固定分组空间上的置换	安全 PRP	要求
结构	代表算法	核心特点	
Feistel 网络	DES	轮函数不必可逆，解密反向使用轮密钥	
SPN	AES	整个状态经过可逆代换和扩散层	
攻击	利用对象		典型防护
穷举	密钥空间过小		足够长密钥
中间相遇	多重加密的中间状态		不朴素串联密码
线性/差分分析	轮函数统计偏差		经公开分析的 S-box 和足够轮数
侧信道	时间、功耗、缓存等实现泄露		成熟的常数时间或硬件实现
故障攻击	错误输出差异		故障检测、冗余计算、硬件防护
Grover 搜索	通用密钥搜索		增加对称密钥长度

20. 常见误区

误区 1: AES-256 的分组长度是 256 位

错误。AES 的分组长度始终是 128 位，256 指密钥长度。

误区 2: 分组密码可以直接安全加密长文件

错误。分组密码只处理固定长度分组，必须配合安全工作模式或 AEAD。

误区 3: PRP 与随机函数完全相同

错误。PRP 是置换，不会让两个不同输入产生相同输出；随机函数允许输出碰撞。

误区 4: 轮函数必须可逆，Feistel 才能解密

错误。Feistel 的整体结构保证可逆，轮函数本身不需要可逆。

误区 5: 两个 56 位密钥串联就有 112 位安全性

错误。双重 DES 受到中间相遇攻击，时间接近 2^{56} 量级，而不是 2^{112} 。

误区 6: 3DES 的有效安全性等于名义 168 位

错误。多重加密结构和中间相遇攻击会降低有效安全强度。

误区 7: AES 算法安全，所以任何 AES 代码都安全

错误。查表、分支、缓存访问、随机数、密钥管理和协议使用都可能泄密。

误区 8: 线性密码分析要求密码完全线性

错误。即使只有极小的线性偏差，大量样本也可能把偏差放大为攻击。

误区 9: 量子计算把 s 位对称密钥直接降为 $s/2$ 位密钥

不够准确。Grover 将通用搜索次数从约 2^s 降至约 $2^{s/2}$ ；实际量子门和纠错成本仍然很大。

误区 10: GGM 是 AES 的实际内部结构

错误。GGM 是从 PRG 构造 PRF 的理论方法；AES 使用专门设计的 SPN。

21. 必会公式与推导

21.1 分组密码正确性

$$D(k, E(k, m)) = m$$

21.2 PRF 区分优势

$$\left| \Pr[A^{F(k, \cdot)} = 1] - \Pr[A^f = 1] \right|$$

21.3 Feistel 单轮与逆变换

$$\begin{aligned}L_i &= R_{i-1}, & R_i &= f_i(R_{i-1}) \oplus L_{i-1} \\ R_{i-1} &= L_i, & L_{i-1} &= f_i(L_i) \oplus R_i\end{aligned}$$

21.4 穷举成本

$$T \approx 2^s$$

21.5 双重加密的中间相遇等式

$$E(k_2, m) = D(k_1, c)$$

21.6 DESX

$$E_X((k_1, k_2, k_3), m) = k_1 \oplus E(k_2, m \oplus k_3)$$

21.7 线性分析样本复杂度

$$N \approx \frac{1}{\varepsilon^2}$$

21.8 Grover 搜索

$$2^s \longrightarrow 2^{s/2}$$

21.9 GGM 递推

$$k_0 = k, \quad k_{i+1} = G(k_i)[x_i], \quad F(k, x) = k_n$$

22. 自测题

题 1

为什么固定密钥下的分组密码必须是置换，而不能只是普通函数？

题 2

真正随机函数与真正随机置换在输出碰撞方面有什么区别？

题 3

设 $G(k, 0) = 0^{128}$ ，其余输入上 $G(k, x) = F(k, x)$ ，其中 F 是安全 PRF。请构造区分器。

题 4

写出 PPT 标记下的一轮 Feistel 正向和逆向公式，并解释为什么 f_i 不需要可逆。

题 5

为什么一组 DES 明密文通常已足够验证穷举找到的密钥？

题 6

双重 DES 的中间相遇攻击如何把 2^{112} 级别的朴素穷举降到接近 2^{56} 级别？

题 7

线性关系只有 2^{-21} 的偏差，为什么仍可用于攻击 DES？

题 8

列出 AES-128 普通轮的四个步骤，以及最后一轮省略的步骤。

题 9

ShiftRows 和 MixColumns 分别承担什么作用？

题 10

GGM 构造如何用输入 $x = x_0x_1 \cdots x_{n-1}$ 选择最终输出？

题 11

写出“安全 PRG 到安全分组密码”的理论构造链。

题 12

在理想 Grover 模型下，AES-128 与 AES-256 分别提供约多少位通用量子搜索安全性？

23. 自测题参考答案

答 1

解密必须从每个密文唯一恢复明文。若两个不同明文映射到同一密文，就无法确定原文，因此固定密钥下必须是一一映射；在相同有限输入输出空间上即为置换。

答 2

随机函数允许不同输入产生相同输出；随机置换严格一一对应，不会发生这种碰撞。

答 3

查询输入 0。若输出 0^{128} 就猜是 G ，否则猜是真随机函数。对 G 命中概率为 1，对随机函数只有 2^{-128} ，优势接近 1。

答 4

正向：

$$L_i = R_{i-1}, \quad R_i = f_i(R_{i-1}) \oplus L_{i-1}$$

逆向：

$$R_{i-1} = L_i, \quad L_{i-1} = f_i(L_i) \oplus R_i$$

逆变换只需重新计算 f_i ，不需求其反函数。

答 5

DES 有 2^{56} 个密钥但有 2^{64} 个分组输出。对固定 (m, c) ，错误密钥碰巧映射到 c 的期望数量仅约 2^{-8} ，因此正确密钥通常唯一。

答 6

预计算所有 $E(k_2, m)$ ，再枚举 k_1 计算 $D(k_1, c)$ 并查表。正确密钥满足两者在中间状态相等。时间约两次 2^{56} 级枚举，代价转化为空间约 2^{56} 。

答 7

偏差可以通过大量独立样本累积。需要约 $1/\varepsilon^2 = 2^{42}$ 组样本，多数表决便能可靠识别该偏差，并恢复部分密钥信息。

答 8

普通轮：SubBytes、ShiftRows、MixColumns、AddRoundKey。最后一轮省略 MixColumns。

答 9

ShiftRows 把各行字节移动到不同列；MixColumns 在每列内混合四个字节。二者结合，使局部变化在后续轮中扩散到整个状态。

答 10

从根种子 k 开始，第 i 层计算 $G(k_i)$ ，按 x_i 选择左半或右半作为 k_{i+1} ，经过 n 层后的 k_n 就是 $F(k, x)$ 。

答 11

$$\text{安全 PRG} \xrightarrow{\text{GGM}} \text{安全 PRF} \xrightarrow{\text{Luby-Rackoff}} \text{安全 PRP}$$

答 12

理想通用量子搜索下，AES-128 约为 2^{64} 搜索复杂度，即约 64 位；AES-256 约为 2^{128} ，即约 128 位。

24. 一页式总结

分组密码

$$E: K \times \{0,1\}^n \rightarrow \{0,1\}^n$$

固定密钥后必须是可逆置换

PRF

随机密钥函数与真正随机函数不可区分

PRP

随机密钥置换与真正随机置换不可区分
AES、3DES 是实际 PRP 候选

Feistel

$L_i = R(i-1)$
 $R_i = f_i(R(i-1)) \text{ XOR } L(i-1)$
 f_i 不必可逆, 整体仍可逆

DES

64 位分组、56 位密钥、16 轮 Feistel
主要问题: 密钥太短, 已被穷举淘汰

中间相遇攻击

$E(k_2, m) = D(k_1, c)$
双重 DES 不具有预期的 112 位安全性

AES-128

128 位分组、128 位密钥、10 轮 SPN
普通轮: SubBytes $\rightarrow$ ShiftRows $\rightarrow$ MixColumns $\rightarrow$ AddRoundKey
最后一轮: 省略 MixColumns

实现安全

数学算法安全不代表实现安全
注意时间、缓存、功耗与故障侧信道

理论构造链

PRG $\rightarrow$ GGM PRF $\rightarrow$ Feistel PRP

25. 学习建议

第一遍: 区分分组长度、密钥长度、PRF、PRP。

第二遍: 不看笔记推导 Feistel 的逆变换和双重 DES 的中间相遇等式。

第三遍: 画出 AES-128 流程, 特别记住初始 AddRoundKey 和最后一轮没有 MixColumns。

第四遍: 独立讲清 PRG $\rightarrow$ GGM PRF $\rightarrow$ Luby-Rackoff PRP 的理论链条。

最后完成第 22 节自测题, 重点检查第 4、6、8、11 题。

范围说明: 本笔记严格以第三课分组密码 PPT 为主。ECB、CBC、CTR 等分组密码工作模式以及认证加密将在后续课程中系统讨论, 因此这里仅说明它们与分组密码原语的边界, 没有提前展开。